Bảo vệ dữ liệu cá nhân theo Luật 91/2025/QH15

PIIGuard Shield

Bảo vệ dữ liệu cá nhân, giữ nguyên giá trị phân tích

Giúp DPO rà soát dữ liệu cá nhân trong PostgreSQL và MongoDB, duyệt cách bảo vệ từng trường và phát hành bản sao an toàn cho Analyst.

MASK REDACT HMAC DROP

Team P-138
Phúc · Tùng · Kiên · Long



Verifier PASS
Sẵn sàng cho Analyst

Luật đã có chế tài, DPO vẫn rà dữ liệu bằng tay

Khung pháp lý mới về dữ liệu cá nhân

Hiệu lực 01/01/2026

Luật Bảo vệ dữ liệu cá nhân 91/2025/QH15

Luật riêng đầu tiên về dữ liệu cá nhân; cấm mua bán, cố ý làm lộ dữ liệu (Điều 7).

Hiệu lực 01/01/2026

Nghị định 356/2025/NĐ-CP

Hướng dẫn thi hành Luật: danh mục dữ liệu cơ bản và nhạy cảm (Điều 3–4), thay NĐ 13/2023.

Ký 19/08/2026

Nghị định 330/2026/NĐ-CP

Xử phạt hành chính về an ninh mạng và bảo vệ dữ liệu cá nhân: chế tài cho từng hành vi.

MỨC PHẠT TIỀN TỐI ĐA · ĐIỀU 8 LUẬT 91/2025

5% doanh thu năm trước: vi phạm chuyển dữ liệu cá nhân xuyên biên giới

10× khoản thu có được: mua bán dữ liệu cá nhân

3 tỷ đ các vi phạm khác về bảo vệ dữ liệu cá nhân

Áp dụng cho tổ chức; cá nhân tối đa bằng một nửa.

Bỏ sót dữ liệu cá nhân

PII rải rác trong hàng trăm cột, văn bản tự do và document MongoDB lồng nhau.

Che sai làm hỏng JOIN

Khóa nối bị che không nhất quán, Analyst mất liên kết giữa các bảng.

Thiếu căn cứ, bằng chứng

Khó chứng minh ai duyệt, theo điều luật nào, đã kiểm tra tác động chưa.

Nguồn: Luật 91/2025/QH15 (Điều 7, 8), NĐ 356/2025/NĐ-CP, NĐ 330/2026/NĐ-CP. Bản gốc trong docs/legal/.

Cổng bảo mật giữa database gốc và Analyst

Database gốc

PostgreSQL · MongoDB
Chỉ đọc, không ghi ngược



PIIGuard Shield

Quét → DPO duyệt
Build → Kiểm chứng
→ Publish

Dataset đã bảo vệ

Bản sao riêng, đã kiểm chứng
Analyst chỉ thấy bản PUBLISHED

4 cách bảo vệ, DPO chọn cho từng trường dữ liệu

MASK

Che dữ liệu

`0912 *** 789`

Che định danh trực tiếp; chỉ còn nhận biết được dạng dữ liệu.

REDACT

Che thực thể (NER)

`Gọi [PHONE] lúc 9h`

Văn bản tự do vẫn đọc được; tên, SĐT, email được thay bằng nhãn.

HMAC

Băm HMAC

`c7f3e1…9a21`

Mã thay thế cố định: vẫn ghép bảng, đếm khách; không giải ngược.

DROP

Loại bỏ

`(cột bị loại)`

Trường rủi ro hoặc không cần cho phân tích; Analyst không nhận cột.

Dữ liệu không phải dữ liệu cá nhân được giữ nguyên (KEEP). Ví dụ trên là dữ liệu tổng hợp.

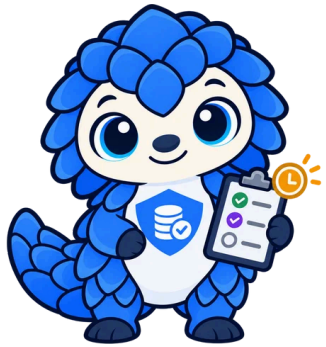
7 bước từ kết nối đến phát hành, có người duyệt

1. **Kết nối nguồn** — chỉ đọc
2. **Chọn phạm vi** — bảng · collection
3. **Quét PII** — rules + AI
4. **DPO duyệt** — có căn cứ pháp lý — Cổng kiểm soát
5. **Build** — bản sao riêng
6. **Kiểm chứng** — thử nối bảng (JOIN) — Cổng kiểm soát
7. **Publish** — Analyst sử dụng



Quét & đề xuất

Rules làm nền, AI hỗ trợ trường mơ hồ. Mỗi trường có phân loại, căn cứ pháp lý và hành động đề xuất.



DPO duyệt trên 4 tab

Tổng quan & phân loại PII · Rủi ro & đánh giá · Nhật ký hoạt động · Dữ liệu cho Analyst. Ghi đè đề xuất của AI bắt buộc ghi lý do.



Có PASS mới Publish

Bản sao được chạy thử phép nối bảng trên cả PostgreSQL và MongoDB. Analyst chỉ thấy dataset đã PUBLISHED.

Dữ liệu đi qua 3 lớp kiểm soát trước khi tới Analyst

ĐƯỜNG DỮ LIỆU

Database gốc
PostgreSQL · MongoDB, chỉ đọc

Bộ xử lý
Quét PII, che theo quyết định của DPO

Bản sao đã bảo vệ
Schema / DB riêng, tạo lại mỗi lần build

Kiểm chứng
Thử nối bảng; chưa PASS thì chặn

Analyst
Chỉ xem dataset đã PUBLISHED

ĐƯỜNG ĐIỀU KHIỂN

Giao diện web
React · Vercel. DPO và Analyst làm việc trên trình duyệt

Máy chủ API
FastAPI · Render. Kiểm tra đăng nhập, vai trò, trạng thái

Nhật ký hoạt động
Mọi thao tác ghi thành chuỗi hash SHA-256

VÌ SAO THIẾT KẾ NHƯ VẬY?

Lớp 1 · Chỉ đọc nguồn

Hệ thống không ghi vào database gốc, nên vận hành của doanh nghiệp không bị ảnh hưởng.

Lớp 2 · Che trên bản sao riêng

Mỗi lần build tạo lại bản sao mới. Cấu hình sai thì sửa và build lại, dữ liệu gốc vẫn nguyên.

Lớp 3 · Kiểm chứng trước khi chia sẻ

Che xong phải chứng minh các bảng vẫn nối được. Chưa PASS thì backend chặn Publish.

Công nghệ: React · TypeScript · MUI · Python 3.11 · FastAPI · LangGraph · PostgreSQL · MongoDB · Docker · GitHub Actions

AI đề xuất, DPO quyết định

LLM chỉ nhận metadata và thống kê đã lọc, không bao giờ nhận giá trị mẫu thô.

Tầng 1 · Regex / rules + taxonomy Luật 91

Tầng 2 · BM25 tri thức phân loại

Tầng 3 · Hybrid vector (ChromaDB)

LLM · chỉ vùng xám · metadata / thống kê

Đề xuất → DPO duyệt (HITL)

HITL few-shot memory

Mỗi lần DPO ghi đè đề xuất, quyết định đó thành ví dụ cho lần quét sau. Tắt AI hoặc LLM lỗi: rules vẫn chạy độc lập.

KẾT QUẢ ĐÁNH GIÁ · SAU HITL

100% — **Action accuracy**
Luồng A · 339 cột CSDL
(trước HITL: 85.25%)

97.86% — **Recall**
Luồng B · văn bản tự do, cascade NER

97.51% — **F1**
Luồng B · Precision 97.16%

Nguồn: performance/sau_HITL/ · dữ liệu tổng hợp

Kiểm thử, CI/CD và nhật ký chống sửa

312
Backend tests pass
pytest · 5 skip (cần DB live)

184
Frontend tests pass
vitest · 42 file test

0
Lỗi Ruff
lint sạch trên src/ và tests/

SHA-256
Nhật ký chuỗi hash
/audit/verify chỉ ra bản ghi bị sửa

Từ commit đến production

Push / Pull request
feature → develop → main

GitHub Actions
Self-hosted runner chạy Ruff + pytest

Release main
Gắn tag SemVer, kích hoạt deploy Render

Production
API trên Render (Docker), web trên Vercel

Không commit .env hay secret · URL nguồn do DPO đăng ký được mã hoá Fernet, không bao giờ trả về · Analyst không có endpoint đọc source.

Test tự động kiểm tra response API và báo cáo không chứa giá trị PII thô; backend chặn Publish khi run chưa VERIFIED.

Số test chạy lại ngày 18/10/2026 trên nhánh hiện tại. CI chạy Ruff + pytest; vitest chạy local.

Ba thách thức và điều chúng em học được

THÁCH THỨC

Che dữ liệu mà vẫn JOIN được

CÁCH XỬ LÝ

HMAC-SHA-256 cho khóa nối, đồng bộ hai đầu quan hệ; link_scope giữ bảng liên kết chỉ có khóa.

THÁCH THỨC

Dùng LLM mà không lộ PII

CÁCH XỬ LÝ

LLM chỉ nhận metadata và thống kê định tính; rules chạy độc lập khi tắt AI hoặc LLM lỗi.

GIỚI HẠN CÒN MỞ

Ngoại lệ KEEP cho PII

VIỆC TIẾP THEO

KEEP vẫn chép giá trị gốc sang bản sao và chưa tự thu hồi theo hạn. Cần chặn trước khi khẳng định Zero Raw PII.

BÀI HỌC LỚN NHẤT

Che dữ liệu chưa đủ, phải chứng minh dataset vẫn dùng được.



Team P-138 và chặng đường tiếp theo

Nguyễn Đình Phúc
PO / Team Lead

Frontend, phạm vi quét, căn cứ pháp lý, pitch

Trần Xuân Tùng
Phát hiện & AI

Rules / LLM, workflow phát hiện, đánh giá AI

Nguyễn Trung Kiên
MongoDB & dữ liệu

Connector MongoDB, fixture, nhãn chuẩn, eval

Đoàn Tuấn Long
Backend & bảo mật

Backend, connector Postgres, guardrail, phân quyền

LỘ TRÌNH TIẾP THEO

01
Chặn KEEP cho PII
Tự thu hồi theo hạn trước khi khẳng định Zero Raw PII.

02
Đồng bộ realtime
CDC với Debezium / Kafka thay cho build theo lần.

03
Quản lý khóa & SSO
KMS / Vault cho khóa HMAC, SSO SAML / OIDC.

04
Thêm nguồn dữ liệu
ClickHouse, Snowflake, Databricks.

Cảm ơn Ban giám khảo đã lắng nghe!

PIIGuard Shield: bảo vệ dữ liệu cá nhân, giữ nguyên giá trị phân tích.

